

Identidad y acceso en red: autenticación, MFA, mínimo privilegio

Parte 1 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

Autenticación fuerte: probar quién eres

Autenticar, autorizar, auditar

Tres preguntas distintas que no se pueden mezclar: quién eres, qué puedes hacer y qué hiciste.

AUTENTICACIÓN

¿quién eres?

contraseña · MFA · certificado

AUTORIZACIÓN

¿qué puedes hacer?

roles · políticas · mínimo privilegio

AUDITORÍA

¿qué hiciste?

registro · trazabilidad · revisión

el error más común no es autenticar mal: es autenticar bien y autorizar de más

Los factores de autenticación

Algo que sabes, algo que tienes, algo que eres — y el contexto que los rodea.



Algo que sabes

contraseña, PIN, frase de paso



Algo que tienes

teléfono, token, tarjeta, certificado en dispositivo



Algo que eres

huella, rostro, voz



Contexto (señal adicional)

ubicación, horario, dispositivo administrado y actualizado

Multifactor de verdad: factores de categorías distintas — contraseña + pregunta secreta NO es doble factor, ambos son «algo que sabes».

Por qué las contraseñas solas ya no bastan

Reutilización, phishing y fuerza bruta: tres formas en que una contraseña deja de proteger.

Los tres ataques

- relleno de credenciales: reutilizar claves filtradas en otros servicios
- phishing: la persona entrega la clave en un sitio falso
- fuerza bruta y bases filtradas: claves cortas o comunes caen rápido

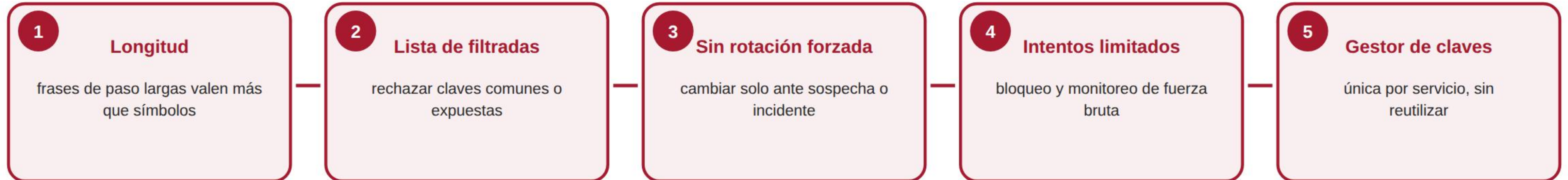
Las tres respuestas

- mejor construcción y gestión de la contraseña (gestor incluido)
- segundo factor que no se pueda adivinar ni copiar del sitio falso
- monitoreo de accesos anómalos y bloqueo por intentos

Dato de diseño: exigir más símbolos sin cambiar nada más empuja a reutilizar y anotar — la complejidad cosmética no es seguridad.

Contraseñas según el estándar

Longitud sobre complejidad, verificación contra listas de filtradas y sin rotación forzada.



Contra la práctica obsoleta: mayúsculas + símbolo + cambio cada 90 días es exactamente lo que produce claves predecibles y anotadas.

MFA: qué combina y por qué cambia el juego

Aunque la contraseña se filtre, el atacante no puede completar la autenticación sin el segundo factor.



el MFA rompe el modelo de negocio de los ataques que asumen que la contraseña basta

Tipos de segundo factor y su resistencia

Del código por mensaje a la llave física: no todos resisten igual al phishing.

el nivel de protección depende del tipo de segundo factor

MÁS DÉBIL



código por mensaje · push simple

interceptable · fatiga de aprobaciones

INTERMEDIO



app autenticadora (código temporal)

resiste filtración pasiva, no phishing activo

MÁS RESISTENTE



llave física o autenticador integrado

verifica el origen · no se reenvía

cuentas privilegiadas piden autenticador resistente al phishing

Cómo se ataca la autenticación hoy

Relleno de credenciales, phishing, fatiga de MFA y robo de sesión — el eslabón humano y el técnico.



Relleno de credenciales

listas filtradas probadas en masa. Defensa: MFA + detección de anomalías + bloqueo por intentos



Phishing

la persona entrega la credencial o aprueba. Defensa: autenticador resistente al phishing + verificación del dominio



Fatiga de MFA

bombardero de aprobaciones hasta que una pasa. Defensa: números de verificación, límites, alertas



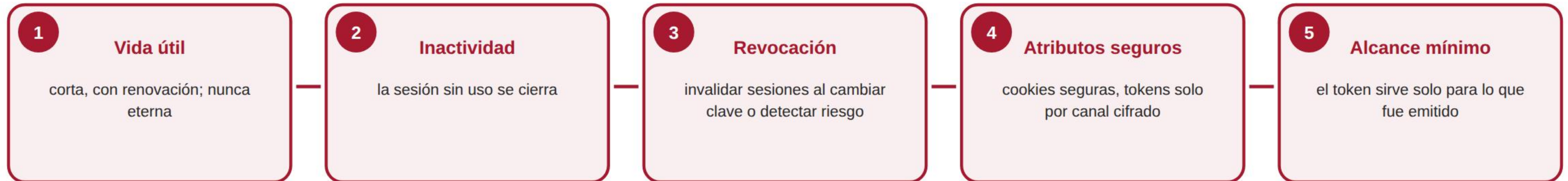
Robo de sesión

cookie o token válido reutilizado. Defensa: tokens cortos, revocación, vínculo al dispositivo

Patrón común: ya no se ataca el algoritmo — se ataca el punto donde la identidad se vuelve un trámite.

Sesiones y tokens: la identidad después del login

Autenticarse una vez no debe significar confiar para siempre: vida, expiración y revocación.



Punto clave: la revocación debe funcionar de verdad — si no se puede invalidar una sesión activa, no hay control real.

Autenticación en la red: 802.1X y RADIUS

Antes de tener dirección IP, el dispositivo ya debería probar quién es.



la identidad empieza en el enlace, no en la aplicación

Cuentas de servicio: identidades sin persona

Aplicaciones, tareas y dispositivos también son identidades — y suelen ser las peor gestionadas.

Malas prácticas

- credencial compartida entre varias aplicaciones
- claves que nunca rotan
- permisos amplios «porque así funciona»
- contraseñas en archivos de configuración o en el código

Buenas prácticas

- una identidad por servicio, con permisos mínimos
- credenciales en un servicio de secretos, rotables
- autenticación por identidad cuando la plataforma lo permite
- registro de uso para auditar

Regla: si una identidad técnica puede hacer más de lo que su función exige, es una vulnerabilidad esperando su momento.

La recuperación de cuentas

El proceso para «olvidé mi contraseña» suele ser más fácil de atacar que el login mismo.



Misma garantía

la recuperación debe exigir un nivel igual o mayor que el login



Notificar cambios sensibles

contraseña, correo, teléfono y pagos: aviso por canal independiente



Soporte no es atajo

si una llamada puede resetear la cuenta, el atacante llamará

Principio: la recuperación es parte del sistema de identidad — se diseña con el mismo rigor, no al final.

Identidad federada: una identidad, varios servicios

Delegar la autenticación en un proveedor de identidad — la base del acceso único.



concentra la autenticación en un punto bien protegido — y lo vuelve dependencia crítica

Lo que queda de la Parte 1

Factores, contraseñas gestionadas, MFA resistente y sesiones controladas — probar identidad con rigor.

3

factores: sabes, tienes, eres — más
señales de contexto

2º

factor resistente al phishing para
cuentas críticas

0

sesiones eternas: vida corta,
expiración y revocación real

1

identidad por servicio: nunca
credenciales compartidas

Siguiente pregunta: una vez que sé quién eres, ¿cómo decido exactamente qué puedes hacer — y cómo lo limito al mínimo necesario?



SEMANA 7 · IDENTIDAD Y ACCESO EN RED: AUTENTICACIÓN, MFA, MÍNIMO PRIVILEGIO

Identidad y acceso en red: autenticación, MFA, mínimo privilegio

Parte 2 de 4 · Unidad 2

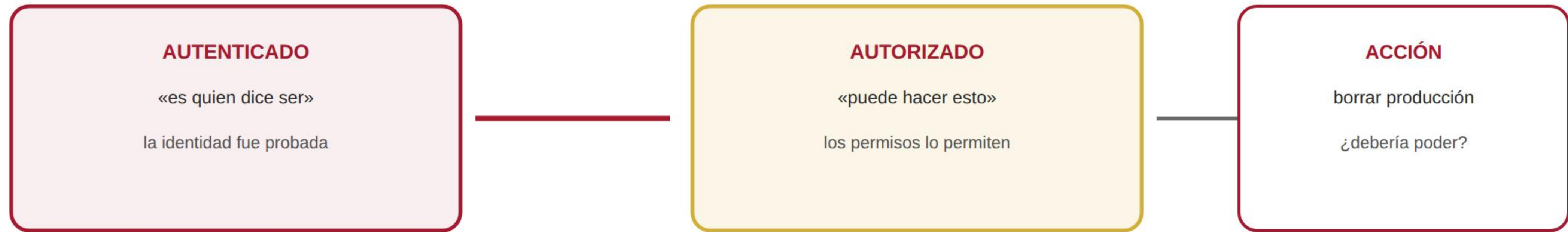
Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

Autorización: decidir qué puedes hacer

Autenticar no es autorizar

Un usuario legítimo puede causar más daño que un atacante si tiene permisos de más.



la mayoría de los incidentes no son usuarios falsos: son usuarios legítimos con permisos de más

Mínimo privilegio, separación y necesidad de saber

Tres principios que ordenan cualquier diseño de autorización.



Mínimo privilegio

exactamente lo necesario, ni más ni menos, y solo el tiempo necesario



Separación de funciones

ninguna persona completa sola una operación sensible



Necesidad de saber

el acceso a la información se limita a quien la necesita para su trabajo

Ejercicio práctico: «si esta cuenta fuera tomada, ¿qué podría hacer?» — la respuesta define qué permisos sobran.

RBAC: permisos a través de roles

Los permisos se asignan a roles por función, y las personas reciben roles — no permisos sueltos.



ABAC: permisos por atributos y condiciones

La decisión no depende solo de quién eres, sino de qué recurso, qué acción y en qué contexto.

Atributos de la decisión

- quién: área, cargo, antigüedad, pertenencia a grupos
- qué recurso: clasificación, dueño, región
- qué acción: leer, escribir, borrar, aprobar
- en qué contexto: horario, ubicación, estado del dispositivo

Fortaleza y costo

- permite políticas que RBAC no puede describir
- se ajusta a decisiones dinámicas por contexto
- la cantidad de combinaciones dificulta entender y auditar
- se adopta por partes y con gobierno

En la práctica: roles para la estructura general + atributos para las condiciones finas — no es reemplazo universal de RBAC.

RBAC o ABAC: cuándo cada uno

Estructura estable y funciones claras piden roles; decisiones contextuales piden atributos.

Usar RBAC

- funciones estables y nombrables
- permisos que no dependen del contexto
- más simple de entender, implementar y auditar
- base por defecto en casi toda organización

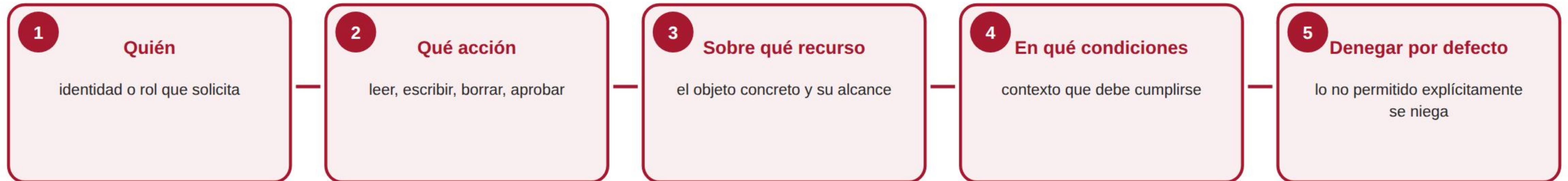
Usar ABAC

- decisiones que dependen de condiciones cambiantes
- acceso según región, clasificación, monto o dispositivo
- cuando la cantidad de roles explotaría
- se agrega solo donde una condición real lo exige

Regla: no adoptar el modelo más expresivo por moda — el más simple que resuelva el requisito real y se pueda auditar.

Cómo se escribe una política

Permitir o denegar, con denegación explícita y evaluación predecible.



Predecible o insegura: si la decisión depende del orden de evaluación o no se puede probar antes de producción, la política no está terminada.

Granularidad: verbo, recurso y alcance

«Puede escribir» no es un permiso: hay que decir sobre qué y hasta dónde.

tres dimensiones de un permiso bien definido

VERBO

leer · crear · modificar

borrar · administrar

RECURSO

tabla · directorio · servicio

cuenta · depósito

ALCANCE

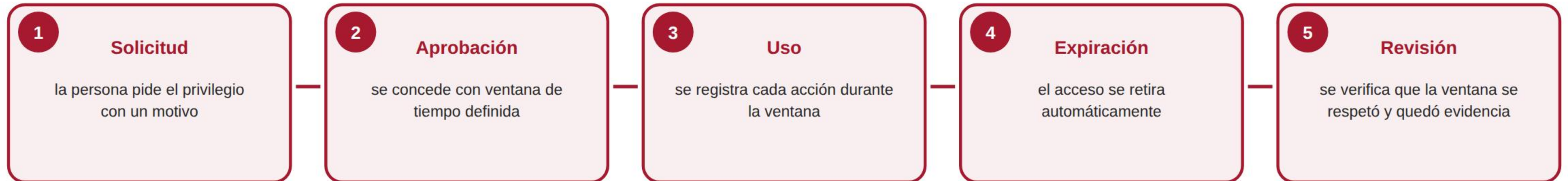
propios datos · su área

toda la organización

«puede escribir» sin recurso ni alcance es una llave maestra, no un permiso

Acceso temporal: just-in-time

Los permisos que se conceden por tarea y se retiran solos reducen el privilegio permanente.



Principio: reducir el privilegio permanente — es el que un atacante encuentra y explota. El acceso permanente debe ser la excepción.

Los permisos se acumulan: revisarlos es obligatorio

Cambios de rol, proyectos cerrados y cuentas olvidadas dejan permisos que nadie usa.

Cómo se acumulan los permisos

- cambio de función: conserva permisos anteriores
- proyectos cerrados: cuentas que quedan activas
- integraciones puntuales: accesos de servicio que nunca se retiran
- resultado: el conjunto excede lo que la función necesita

Cómo se controlan

- inventario de identidades y permisos
- contraste con lo que exige cada función
- retiro de lo que sobra y de cuentas inactivas
- revisión más frecuente de accesos privilegiados

No es papeleo anual: es el mantenimiento que mantiene la autorización alineada con la realidad.

Separación de funciones y doble control

Ninguna persona completa sola una operación sensible — el principio de los cuatro ojos.



Roles que se excluyen

una misma identidad no puede tener dos permisos incompatibles



Flujo de aprobación

quien solicita no aprueba; queda registro de ambos pasos



Cuatro ojos

dos personas deben ver y aprobar la operación sensible

Protege contra dos cosas: el fraude interno y el error honesto — el diseño asume que cualquiera puede equivocarse.

Los cinco errores clásicos de autorización

Todos son de diseño, no de tecnología — y todos aparecen en auditorías reales.



Permiso comodín

administrador «para no complicarse»:
cualquier compromiso es catástrofe



Rol por persona

cada persona con su propio conjunto:
imposible de revisar



Credencial compartida

varias personas o servicios con la misma
cuenta: sin trazabilidad



Permiso heredado

accesos que sobreviven a cambios, cierres e
integraciones



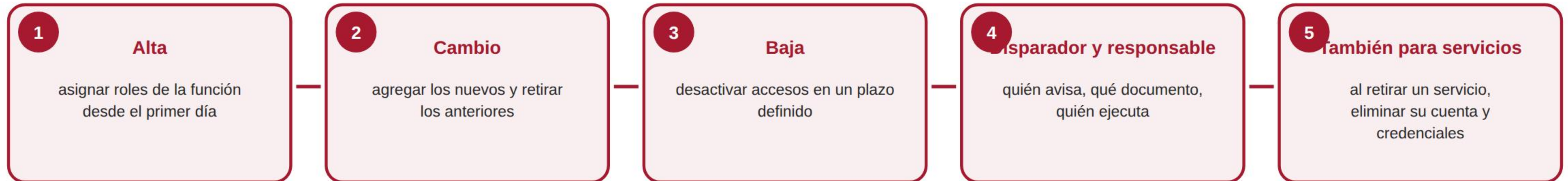
Sin revisión

cuentas inactivas y privilegios que crecen
solos

Ninguno es tecnología difícil: son diseño y disciplina — y son lo que un auditor buscará primero.

Alta, cambio y baja: la identidad cambia

Todo diseño de acceso debe contemplar el ingreso, el cambio de función y la salida.



Fuente principal de privilegios sobrantes: cambios de función mal gestionados y bajas que nunca se procesaron.

Lo que queda de la Parte 2

Mínimo privilegio en la práctica: roles claros, políticas predecibles, revisión continua.

3

principios: mínimo privilegio ·
separación · necesidad de saber

2

modelos: RBAC para la estructura, ABAC
para el contexto

0

permisos comodín: el atajo que
convierte un compromiso en catástrofe

ciclo

conceder → usar → revisar → retirar: la
autorización se mantiene

Siguiente pregunta: si la red ya no es el perímetro y cada acceso se decide por identidad y contexto, ¿cómo se diseña la seguridad de extremo a extremo?



SEMANA 7 · IDENTIDAD Y ACCESO EN RED: AUTENTICACIÓN, MFA, MÍNIMO PRIVILEGIO

Identidad y acceso en red: autenticación, MFA, mínimo privilegio

Parte 3 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

Zero Trust: la identidad como perímetro

El perímetro tradicional y su límite

«Dentro de la red = confiable» funcionó mientras todo estaba dentro. Ya no.

MODELO TRADICIONAL

frontera fuerte, interior confiable

quien entra, se mueve libre

movimiento lateral sin obstáculos

REALIDAD ACTUAL

nube, remoto, servicios y terceros

el interior ya no es un lugar

cada acceso debe verificarse

el supuesto a eliminar: estar dentro = ser confiable

Los principios de Zero Trust

Nunca confiar, verificar siempre: decisiones por solicitud, política dinámica y sin confianza por ubicación.



Sin confianza por ubicación

estar en la red corporativa no otorga confianza implícita



Acceso por solicitud

cada acceso se evalúa y se limita a lo que esa sesión necesita



Política dinámica

identidad + estado del dispositivo + sensibilidad del recurso + contexto



Asumir el compromiso

se monitorea la postura y el comportamiento como parte de la decisión



Verificar antes y durante

la autorización se aplica antes de conceder y se reevalúa en la sesión

«Nunca confiar, siempre verificar»: la seguridad se distribuye en cada punto de decisión, no en una sola frontera.

Microsegmentación: acceso por aplicación

En lugar de confiar en un segmento de red, se autoriza el acceso a la aplicación concreta.

Segmentación por zonas (Unidad 1)

- separa la red en segmentos (usuarios, servidores, DMZ)
- limita el movimiento entre zonas
- el control se expresa por red o subred

Microsegmentación (Zero Trust)

- cada aplicación acepta solo tráfico de identidades específicas
- el control se afina al servicio individual
- comprometer una app no da acceso a las demás
- las reglas se basan en identidad, no solo en dirección

Beneficio: contención del movimiento lateral. **Costo:** conocer y mantener qué servicio habla con cuál — parte de la arquitectura, no una tarea aparte.

Verificar una vez no basta

La confianza de una sesión debe caducar: se reevalúa con cada cambio de contexto.

la confianza de una sesión cambia con el contexto

inicio de sesión: identidad + MFA verificados

durante la sesión: postura del dispositivo, ubicación, comportamiento

si el contexto empeora: reevaluar, degradar o revocar el acceso

verificar continuamente no es molestar en cada clic: es conocer el estado del acceso y reaccionar

La postura del dispositivo

El mismo usuario, con un equipo distinto, no es el mismo nivel de confianza.



¿Administrado?

equipo de la organización vs. equipo personal desconocido



¿Cifrado y protegido?

cifrado de disco y protección antimalware al día



¿Parcheado?

actualizaciones de seguridad aplicadas



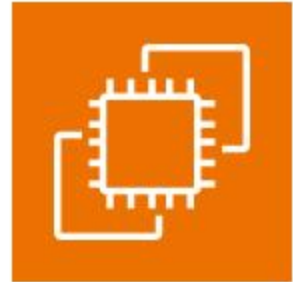
Decisión por postura

acceso completo, limitado o denegado según el estado del equipo

Sin señal no hay política: la postura requiere instrumentación que la reporte y un mecanismo confiable que la verifique.

La identidad como plano de control

Personas, servicios y dispositivos son identidades — y todas pasan por la misma decisión de acceso.



Identidades humanas
empleados · admins



Identidades de servicio
apps · funciones



Identidades de dispositivo
equipo · servidores

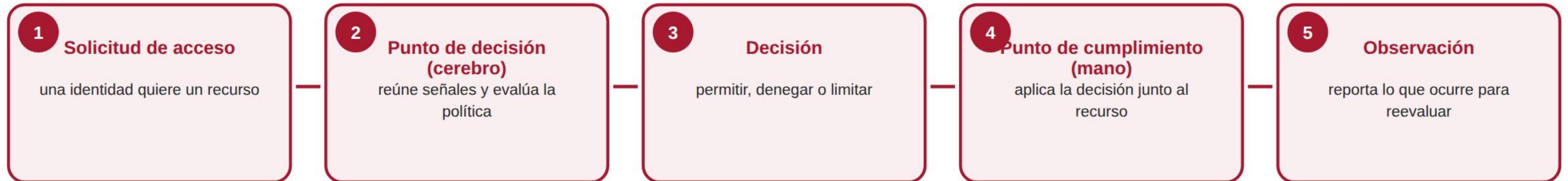
DECISIÓN: identidad + recurso + acción + contexto

el sistema de identidad es infraestructura crítica

«la identidad es el nuevo perímetro»: el acceso se decide en la identidad, no en la red

Quién decide y quién aplica

Un punto de decisión evalúa la política; un punto de cumplimiento la ejecuta en el acceso.



Coherencia: una sola lógica de decisión y puntos de aplicación consistentes — si cada punto aplica reglas distintas, la arquitectura tiene agujeros.

ZTNA y la VPN clásica

De un túnel que da acceso a la red, a un acceso específico a la aplicación solicitada.

VPN clásica

- túnel que da acceso amplio a la red interna
- la confianza se concede por estar dentro
- mayor superficie de movimiento lateral
- útil para conectar sedes e infraestructura

ZTNA (acceso de confianza cero)

- acceso específico a la aplicación solicitada
- verifica identidad, dispositivo y contexto
- no expone el resto de la red
- la VPN queda como transporte, no como frontera

Continuidad con S06: la VPN no desaparece — cambia su papel; el acceso de usuarios se mueve hacia ZTNA.

Identidades de servicio y mTLS

Los servicios también se autentican entre sí: la misma disciplina, sin personas de por medio.



Servicio A
certificado propio

mTLS: ambos verifican



Servicio B
certificado propio

AUTORIZACIÓN ENTRE SERVICIOS

qué servicio puede llamar a cuál y con qué alcance
certificados emitidos y rotados por una autoridad interna

sin esto, cualquier servicio comprometido puede llamar a todos los demás

Zero Trust no es un producto: es madurez

Se construye por etapas, empezando por lo más crítico y por las identidades más privilegiadas.



Cada etapa reduce riesgo por sí sola — el programa completo tarda años; el intento de hacerlo todo de golpe suele quedar a medio camino.

Tres escenarios de aplicación

Empleados, servicios y terceros: la misma lógica con señales y políticas distintas.



Empleados

MFA + postura del dispositivo + acceso a las apps de su función, sin exponer la red



Servicios

identidad por servicio + mTLS + autorización de llamadas entre servicios



Terceros

acceso específico, con duración definida, verificación fuerte y registro detallado

Los terceros son el eslabón débil: un proveedor comprometido con acceso amplio es una de las vías de ataque más usadas.

Los costos reales de Zero Trust

Complejidad, inversión y fatiga de políticas: la honestidad que exige un diseño maduro.



Complejidad

políticas por identidad y contexto multiplican las decisiones a mantener



Inversión

identidad, dispositivos, malla de servicios y observabilidad compiten con otros proyectos



Fatiga de políticas

reglas poco explicadas producen excepciones permanentes que vacían el modelo



Riesgo de sobreconfianza

reduce superficie, no elimina el error humano ni las fallas de las aplicaciones

La alternativa tiene costos peores: adoptar por etapas, medir el riesgo reducido y evitar que se vuelva una etiqueta de mercadeo.

Lo que queda de la Parte 3

Sin confianza por ubicación, decisión por sesión, identidad como plano de control y adopción por etapas.

sin ubicación

ninguna identidad es confiable por
estar en la red

por sesión

cada acceso se evalúa y se limita a lo
necesario

3 identidades

humanas, de servicio y de dispositivo

por etapas

inventariar → privilegiados → sensibles
→ microsegmentar → observar

Puente a la Parte 4: ahora hay que diseñar — en el ejercicio propio, el control de acceso completo de un escenario con identidades, roles y políticas.

SEMANA 7 · IDENTIDAD Y ACCESO EN RED: AUTENTICACIÓN, MFA, MÍNIMO PRIVILEGIO

Identidad y acceso en red: autenticación, MFA, mínimo privilegio

Parte 4 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

Ejercicio propio de control de acceso y cierre

El ejercicio de la semana

Diseñar un control de acceso completo para un escenario — sin herramienta, con criterio.

Ejercicio propio de control de acceso · Unidad 2

Diseño de identidades, roles, políticas y revisión para un escenario dado. **Sin laboratorio de nube:** se evalúa el razonamiento y la coherencia del diseño.



Identidades

personas, servicios y dispositivos del escenario



Recursos

qué hay que proteger y con qué acciones



Roles y políticas

permisos mínimos y condiciones



Revisión

cómo se audita y se retira lo que sobra

No hay una única respuesta correcta: se evalúa que cada permiso esté justificado, que no haya privilegios de más y que el diseño contemple el cambio.

El caso que vamos a diseñar

Una empresa pequeña con tres áreas, dos aplicaciones y datos de clientes — supuestos didácticos.



supuestos didácticos — lo que importa es el método, no los nombres

Inventario de identidades

Personas, servicios y dispositivos: sin este inventario no se puede diseñar nada.



Humanas

3 áreas + 2 administradores + proveedores externos



De servicio

aplicaciones y tareas automatizadas que se autentican



De dispositivo

equipos concretos en los que confía un recurso



Datos por identidad

área, interna/externa, remoto, nivel de privilegio

Error frecuente: inventariar solo personas y olvidar servicios e integraciones — que son las cuentas con más permisos y menos vigilancia.

Inventario de recursos y acciones

Qué hay que proteger y qué operaciones se realizan sobre cada cosa.

recursos por sensibilidad y acciones típicas

RECURSOS

datos de clientes · información de facturación
configuración de aplicaciones · registros
cuentas y permisos (administrativo)
clasificación por sensibilidad

ACCIONES

consultar · crear · modificar · borrar
aprobar · exportar · administrar usuarios
sensibilidad crece con el alcance y el efecto
acciones administrativas = control estricto

Definir roles y permisos mínimos

Agrupar permisos por función y asignar a cada identidad solo el rol que necesita.



Agente de atención

consultar y modificar solicitudes de su área; sin exportar todo



Analista de operaciones

consultar y exportar informes de su área



Administrativo

generar facturas y ver pagos; no aprobar pagos



Administrador de tecnología

administrar usuarios y configuración, con separación de funciones

Revisión de cada rol: «si esta cuenta fuera comprometida, ¿podría hacer algo que su función no necesita?» — si sí, el rol está de más.

Condiciones y controles adicionales

MFA, postura del dispositivo, horario y ubicación: cuándo se exige cada control.



Se gradúa, no se uniforma: el control se asigna según el riesgo de cada acceso — MFA resistente para todos puede ser tan poco práctico como para nadie.

La matriz de acceso: el resultado visible

Una tabla recurso × rol que hace evidente el diseño y sus huecos.

matriz de acceso (ejemplo didáctico: ✓ permitido · — no permitido)

ROL / RECURSO	Solicitudes	Datos cliente	Facturas	Pagos	Usuarios
Agente atención	✓	✓	—	—	—
Analista operaciones	✓	—	✓	—	—
Administrativo	—	—	✓	✓	—
Administrador tecnología	—	—	—	—	✓

los administradores no aprueban pagos ni ven datos de cliente: separación de funciones

Revisión y auditoría del acceso

El diseño no termina en la matriz: hay que mantenerlo y poder auditarlo.



Sin registros no hay auditoría: este paso conecta con la semana 8 (monitoreo y logging). Un diseño sin revisión envejece desde el primer día.

Qué se evalúa en el ejercicio

Coherencia, justificación, mínimo privilegio y previsión del cambio — no una respuesta única.



Coherencia

identidades, recursos, roles y políticas encajan sin contradicciones



Justificación

cada permiso tiene una razón funcional



Mínimo privilegio

ningún rol con más acceso del necesario; separación de funciones



Previsión del cambio

cómo se incorpora, se retira, se revisa y se audita



Claridad

un diseño que nadie puede leer es un diseño que nadie mantiene

Pregunta incómoda de preparación: si la cuenta de cada rol cayera en manos de un atacante, ¿qué podría hacer? Si excede lo razonable, hay trabajo pendiente.

Errores típicos en este tipo de ejercicio

Cinco patrones que bajan la calidad de un diseño de control de acceso.



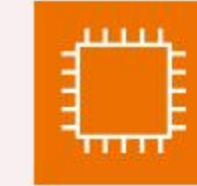
Olvidar servicios y dispositivos

diseñar solo para personas deja las cuentas más peligrosas sin gobierno



Roles por persona

hace el diseño inmantenible y difícil de revisar



Permisos sin justificar

«tal vez los necesite» es lo contrario del mínimo privilegio



Sin separación de funciones

un mismo rol genera y aprueba, o crea usuarios y asigna privilegios



Sin plan de revisión

entregar la matriz sin explicar cómo se mantiene correcta

Son errores de razonamiento, no técnicos: se evitan recorriendo el método completo sin saltarse pasos.

La semana siguiente: monitorear lo que se diseña

Un control de acceso sin observación es una intención; el logging lo convierte en evidencia.

dos mitades del mismo control

ESTA SEMANA 7

diseñar quién puede hacer qué

identidades · roles · políticas · revisión

el diseño define lo que es normal

SEMANA 8

comprobar qué se hizo

registro · correlación · detección

el logging da evidencia del cumplimiento

sin diseño no se sabe qué es normal; sin registro no se puede demostrar que se cumple

Semana 7 en cuatro ideas

Probar identidad, decidir acceso, llevar Zero Trust a fondo y diseñarlo en la práctica.

autenticar

factores, contraseñas gestionadas, MFA
según riesgo

autorizar

mínimo privilegio, separación,
necesidad de saber

Zero Trust

sin confianza por ubicación; identidad
como plano de control

diseñar

identidades · roles · condiciones ·
revisión justificada

Entregable S7: ejercicio propio de control de acceso. **Próxima semana S8:** monitoreo y logging + Lab 6.1 AWS (CloudTrail/CloudWatch, 10 %).

De la identidad a la evidencia

Ya se decidió el acceso; ahora hay que poder demostrar qué ocurrió.

la Unidad 2 y sus tres piezas



diseñar para poder demostrar: sin evidencia, el diseño es una promesa sin prueba